



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-12569 PTC Windchill and FlexPLM RCE Exploitation Report

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-12
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-12569 PTC Windchill and FlexPLM RCE Exploitation Report - CVE / Vulnerability Threat Intelligence Report

Published: 2026-08-12 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Key Judgments
3. Vulnerability Metadata
4. Source Review and Confidence
5. Attack Chain Assessment
6. Threat Landscape and Victimology
7. Affected Products and Exposure Review
8. Indicators of Compromise and Observable Patterns
9. Mitigation and Workarounds
10. Detection Engineering
 - 10.1. Sigma: Potential Windchill Randomized JSP Webshell Access
 - 10.2. Sigma: Suspicious Windchill WSDL Reconnaissance
 - 10.3. YARA: Windchill JSP Webshell and Campaign Strings
 - 10.4. Suricata: Windchill Campaign Header
11. Threat Hunting
 - 11.1. Microsoft Defender KQL: Webshell Path and WSDL Recon
 - 11.2. Microsoft Defender KQL: Java/Tomcat Child Process Execution
 - 11.3. Splunk SPL: Windchill Webshell and Header Hunt
 - 11.4. Filesystem Hunt Checklist
12. MITRE ATT&CK Mapping
13. Validation and Lab Testing
14. Recommended Actions Summary
15. References

CVE-2026-12569 PTC Windchill and FlexPLM RCE Exploitation Report

1. Executive Summary

CVE-2026-12569 is now more than a generic critical PTC Windchill and FlexPLM remote code execution issue. Updated vendor and public reporting support treating it as an active Cl0p data-theft/extortion campaign against internet-exposed product lifecycle management environments. PTC identified the issue as a critical vulnerability that could allow an unauthorized user to execute code remotely, and CISA added the CVE to the Known Exploited Vulnerabilities catalog on 2026-06-25.

The material update is operational: Ransom-ISAC, eCrime.ch, and DEFUSED describe suspected Cl0p affiliate activity chaining a pre-authentication FlexPLM WSDL information disclosure with Windchill login servlet exploitation, deploying randomized JSP web shells under Windchill login paths, staging file listings, and sending extortion emails tied to alleged Windchill data theft. PTC's advisory content also lists known webshell paths, source-reported network indicators, and hunt patterns for randomized JSP naming.

Lost Boys Cyber assesses this as a critical same-day remediation and compromise-assessment priority for manufacturing, aerospace, automotive, retail/apparel, defense-industrial, and engineering organizations. Patch status alone is insufficient: organizations with exposed Windchill or FlexPLM between early June and remediation should preserve logs, hunt webshell paths and suspicious request headers, inspect filesystem artifacts, review outbound connections to source-reported infrastructure, and assess whether sensitive product/design data was accessed or staged.

2. Key Judgments

Judgment	Assessment	Confidence
Exploitation status	CISA KEV and coordinated public reporting support known exploitation.	High
Actor context	Ransom-ISAC reporting attributes observed extortion activity to alleged Cl0p ransomware affiliate activity; direct attribution should remain incident-specific until victim evidence confirms it.	Medium-High
Primary exposed surface	Internet-exposed Windchill/FlexPLM application tiers, especially login and FlexPLM WSDL surfaces.	High
Likely impact	Data theft/extortion against engineering, PLM, manufacturing, and supplier data is more likely than immediate encryption-first ransomware in the reported campaign.	Medium-High
Defender priority	Patch, isolate, and hunt for compromise before treating remediation as complete.	High

3. Vulnerability Metadata

Field	Value
CVE	CVE-2026-12569
Vendor / Products	PTC Windchill PDMlink and PTC FlexPLM
Weakness	Untrusted-data/deserialization remote code execution condition

Severity	Critical; CVSS v3.1 9.8 described by Ransom-ISAC; KEV-listed by CISA
CISA KEV	Added 2026-06-25
Reported actor/campaign	Alleged ClOp affiliate exploitation of internet-exposed Windchill/FlexPLM deployments
Campaign tradecraft	FlexPLM WSDL reconnaissance/disclosure, Windchill login servlet exploitation, JSP webshells, file listing/staging, data-theft extortion
Current report version	1.1 updated 2026-08-12 with ClOp campaign context, IOCs, and stronger detections/hunts

4. Source Review and Confidence

Source	Contribution	Confidence
PTC advisory / CS473270 and public Trust Center page	Vendor acknowledgement, affected-version/remediation direction, known paths, network indicators, request/header hunt guidance.	High
CISA Known Exploited Vulnerabilities Catalog	Establishes known exploitation and federal remediation urgency.	High
Ransom-ISAC, eCrime.ch, DEFUSED unified advisory	ClOp campaign context, WSDL + Windchill chain, indicators, extortion behavior, victim-sector framing.	Medium-High
BleepingComputer / The Hacker News coverage	Public reporting that ClOp targeted exposed Windchill/FlexPLM systems in data-theft attacks.	Medium
NVD CVE detail	Baseline CVE description and scoring reference.	High for CVE identity; lower for fast-moving exploitation detail

5. Attack Chain Assessment

Phase	Observed or Plausible Activity	Defender Evidence
Reconnaissance	GET requests to FlexPLM/Windchill WSDL-style endpoints such as /Windchill/rfa/jsp/login/*.jsp?wsdl.	WAF/proxy logs, application access logs, response-size anomalies.
Initial Access	Unauthenticated RCE against exposed Windchill/FlexPLM application paths.	POST requests to /Windchill/login/*.jsp or randomized JSP paths; unusual p= or c= parameters.
Execution	JSP webshell command execution through login-path implants.	Java/Tomcat spawning shell utilities; command parameters; child processes from application service accounts.
Persistence	Randomized JSP files under login/application paths.	Files matching /Windchill/login/[0-9a-f]{16}.jsp, /Windchill/login/[0-9a-fA-F]

		{6}.jsp, or dpr-style names.
Collection	File listing, staging, and product/design-data enumeration.	flst.txt, abnormal archive/file reads, large recursive directory listings, PLM repository access.
Exfiltration	Data transfer to actor-controlled infrastructure.	Outbound connections from Windchill/FlexPLM hosts to source-reported IPs and unusual cloud/VPS destinations.
Extortion	Broad employee emails claiming Windchill module data leak.	Mailbox reports, external sender analysis, leak-site monitoring, incident comms intake.

6. Threat Landscape and Victimology

PTC Windchill and FlexPLM often hold intellectual property, bills of material, engineering workflows, supplier attachments, compliance records, and product lifecycle data. That makes the campaign strategically aligned with ClOp's mass-exploitation extortion model: compromise a widely deployed enterprise platform, steal valuable records at scale, and pressure victims publicly rather than relying only on encryption.

Reported victim sectors include manufacturing, automotive, aerospace, and retail/apparel. Lost Boys Cyber also assesses elevated exposure for defense-industrial suppliers, aviation/aerospace manufacturers, medical-device manufacturers, and any organization where PLM data is linked to regulated product, safety, export-control, or supplier information.

7. Affected Products and Exposure Review

Exposure Pattern	Why It Matters	Evidence to Collect
Internet-exposed Windchill/FlexPLM	Direct exposure allows pre-auth probing and exploitation attempts without VPN/ZTNA barriers.	External ASM results, firewall NAT rules, WAF logs, reverse-proxy hostnames.
Partner-accessible PLM portals	Supplier access can create semi-public attack surfaces and hard-to-monitor remote traffic.	Partner IP allowlists, IdP logs, portal access audit trails.
Legacy release/CPS levels	Vendor patches and mitigations are release-specific; unsupported or lagging CPS levels remain high-risk.	Version inventory, CPS levels, PTC patch/hotfix records.
Application server file write access	RCE becomes durable when attackers can place JSP webshells in executable paths.	File integrity monitoring, webroot diffing, Tomcat/Windchill deployment directories.
Sensitive design/product repositories	Data theft can create competitive, regulatory, and supplier-chain risk.	File access logs, exports, archive creation, abnormal downloads.

8. Indicators of Compromise and Observable Patterns

The indicators are preserved in iocs.csv and should be handled as campaign-scoped intelligence. Exact indicators support retrospective triage, while randomized JSP naming patterns, suspicious request headers, WSDL recon paths, app-server child processes, and abnormal data staging behavior are more durable than any single IP.

Type	Values
Priority source-reported IPs	216.152.148.54, 216.152.151.204, 104.243.35.63, 5.180.41.35, 38.60.157.212, 64.177.69.57, 64.177.86.200, 65.20.79.73,

	66.163.122.78, 74.50.76.146, 78.128.113.10, 79.141.163.103
Additional source-reported IPs/CIDR	81.27.103.18, 81.27.103.68, 85.9.211.83, 87.58.193.42, 104.194.9.14, 104.238.145.147, 104.243.35.0/24, 104.243.35.131, 111.194.46.135, 137.184.184.209, 138.68.51.132, 144.172.101.13, 162.243.242.176, 172.111.38.31, 185.227.83.236, 204.194.51.30, 206.189.199.39, 209.222.98.44, 212.147.249.110
Known webshell examples	/Windchill/login/7c0a0a34c9d8d53b.jsp; /Windchill/login/46b158b8607a4c00.jsp; /Windchill/login/ec6ba805a076e709.jsp
Durable path patterns	/Windchill/login/[0-9a-f]{16}.jsp; /Windchill/login/[0-9a-fA-F]{6}.jsp; /Windchill/login/dpr+[0-9a-fA-F]{6}.jsp
Header / artifact	X-windchill-req: ?x8Fmgow; flst.txt

9. Mitigation and Workarounds

Priority	Owner	Action
Critical	Application owners	Apply PTC remediation for all affected Windchill/FlexPLM versions and CPS levels; verify actual package/hotfix installation.
Critical	Network/security engineering	Remove direct internet exposure; place Windchill/FlexPLM behind VPN/ZTNA and restrict partner ingress to explicit allowlists.
Critical	Incident response	If exposed before remediation, preserve web, WAF, proxy, application, and EDR logs before rotation and perform compromise assessment.
High	Detection engineering	Deploy webshell, header, WSDL, and app-server child-process hunts from this report.
High	Identity/security operations	Review new accounts, role changes, service-account behavior, and mass file access tied to PLM applications.

10. Detection Engineering

10.1. Sigma: Potential Windchill Randomized JSP Webshell Access

<pre> title: Potential PTC Windchill Randomized JSP Webshell Access id: lbc-cve-2026-12569-windchill-random-jsp-webshell status: experimental description: Detects HTTP requests to randomized JSP paths under Windchill login locations associated with CVE-2026-12569 exploitation reporting. logsource: category: webserver detection: selection_path: cs-uri-stem re: '/windchill/login/([0-9a-f]{16} [0-9a-fA-F]{6} dpr[_+]?[0-9a-fA-F]{6,8})\.jsp\$' selection_method: cs-method: </pre>
--

```
- POST
- GET
condition: selection_path and selection_method
level: high
```

10.2. Sigma: Suspicious Windchill WSDL Reconnaissance

```
title: Suspicious PTC Windchill FlexPLM WSDL Reconnaissance
id: lbc-cve-2026-12569-windchill-wsdl-recon
status: experimental
description: Detects WSDL-style reconnaissance paths reported in the CVE-2026-12569 Cl0p exploitation chain.
logsource:
  category: webserver
detection:
  selection:
    cs-uri-stem|contains: '/Windchill/rfa/jsp/login/'
    cs-uri-query|contains: 'wsdl'
  condition: selection
level: medium
```

10.3. YARA: Windchill JSP Webshell and Campaign Strings

```
rule LBC_CVE_2026_12569_Windchill_Webshell_Artifacts {
  strings:
    $h1 = "X-windchill-req" ascii wide
    $h2 = "?x8Fmgow" ascii wide
    $f1 = "flst.txt" ascii wide
    $p1 = "/Windchill/login/" ascii wide
    $cmd1 = "cmd=" ascii wide
    $cmd2 = "whoami" ascii wide
  condition:
    2 of them
}
```

10.4. Suricata: Windchill Campaign Header

```
alert http any any -> $HOME_NET any (msg:"LBC CVE-2026-12569 PTC Windchill suspicious X-windchill-req header"; flow:to_server,established; http.header; content:"X-windchill-req"; nocase; http.header; content:"?x8Fmgow"; nocase; classtype:web-application-attack; sid:4261256901; rev:1; metadata:tlp clear, cve CVE_2026_12569;)
```

11. Threat Hunting

11.1. Microsoft Defender KQL: Webshell Path and WSDL Recon

```
DeviceNetworkEvents
| where Timestamp > ago(45d)
| where RemoteUrl has_any ("/Windchill/login/", "/Windchill/rfa/jsp/login/", "X-windchill-req", "?x8Fmgow", "flst.txt")
| where RemoteUrl matches regex @"\/Windchill\/login\/([0-9a-f]{16}|[0-9a-fA-F]{6}|dpr[_+]?[0-9a-fA-F]{6,8})\.jsp" or RemoteUrl has "wsdl" or RemoteUrl has "X-windchill-req"
| project Timestamp, DeviceName, RemoteIP, RemoteUrl, InitiatingProcessFileName, AdditionalFields
```

11.2. Microsoft Defender KQL: Java/Tomcat Child Process Execution

```
DeviceProcessEvents
| where Timestamp > ago(45d)
| where InitiatingProcessFileName in~ ("java.exe", "java", "tomcat.exe", "tomcat", "httpd.exe", "w3wp.exe")
| where ProcessCommandLine has_any ("cmd.exe", "powershell", "bash", "sh -c", "curl", "wget", "certutil", "whoami", "id", "net user")
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName, ProcessCommandLine, AccountName
```

11.3. Splunk SPL: Windchill Webshell and Header Hunt

```
(index=web OR index=waf OR sourcetype=access_combined)
(uri_path="/Windchill/login/*" OR uri="*/Windchill/rfa/jsp/login/*wsdl*" OR http_header="*X-windchill-
```

```
req*" OR _raw="*?x8Fmgow*")
| regex uri_path="/Windchill/login/([0-9a-f]{16}|[0-9a-fA-F]{6}|dpr[_+]?[0-9a-fA-F]{6,8})\.jsp"
| stats count min(_time) as first_seen max(_time) as last_seen values(uri) as uri values(useragent) as
useragent by src_ip dest host
```

11.4. Filesystem Hunt Checklist

- Search Windchill web/application directories for unexpected JSP files, especially /Windchill/login/[0-9a-f]{16}.jsp, 6-character JSP names, and dpr-style JSP names.
- Search for flst.txt, archive files created by application service accounts, and large recently modified files near web roots.
- Compare application directories against clean backups or vendor media rather than relying only on timestamps.
- Review outbound network connections from Windchill/FlexPLM hosts to source-reported IPs during the suspected exposure window.

12. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Reported initial access against internet-exposed Windchill/FlexPLM.
T1505.003	Server Software Component: Web Shell	JSP webshell deployment under Windchill login paths.
T1059	Command and Scripting Interpreter	Webshell command execution and suspicious command patterns.
T1083	File and Directory Discovery	flst.txt and file listing/staging behavior.
T1005	Data from Local System	Product/design data access from PLM repositories.
T1041	Exfiltration Over C2 Channel	Data-theft extortion requires outbound transfer from compromised systems.

13. Validation and Lab Testing

No exploit reproduction was performed. Validation completed for this update includes source triangulation from PTC, CISA, and Ransom-ISAC reporting; IOC normalization into iocs.csv; report source expansion; and detection/hunt content generation. Operators should validate all field names against local WAF, proxy, EDR, and application logging schemas before production deployment.

14. Recommended Actions Summary

Priority	Action	Expected Outcome
Critical	Patch or mitigate every affected Windchill/FlexPLM deployment and verify actual version/CPS state.	Removes known exploit path.
Critical	Preserve and review access logs for the full suspected exposure window.	Prevents loss of webshell/recon evidence.
High	Hunt for randomized JSP paths, X-windchill-req, WSDL recon, flst.txt, Java child processes, and source-reported IPs.	Finds evidence of exploitation or post-exploitation.
High	Review PLM data access and outbound	Determines whether data-theft assessment

	transfer activity.	is needed.
Medium	Add Windchill/FlexPLM to recurring external attack-surface and version-drift monitoring.	Reduces future exposure windows.

15. References

- [1] PTC Customer & Partner Updates: Remote Code Execution Vulnerability in PTC Windchill and FlexPLM Solutions. <https://www.ptc.com/en/about/trust-center/advisory-center/active-advisories/windchill-flexplm-rce-vulnerability>
- [2] PTC eSupport article CS473270. <https://www.ptc.com/en/support/article/CS473270>
- [3] CISA Known Exploited Vulnerabilities Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [4] NVD CVE-2026-12569. <https://nvd.nist.gov/vuln/detail/CVE-2026-12569>
- [5] Ransom-ISAC, eCrime.ch, DEFUSED: Cl0p Exploitation of PTC Windchill & FlexPLM (CVE-2026-12569). <https://ransom-isac.org/blog/cl0p-windchill-flexplm-exploitation/>
- [6] BleepingComputer: Cl0p ransomware targets Windchill, FlexPLM in data theft attacks. <https://www.bleepingcomputer.com/news/security/cl0p-ransomware-targets-windchill-flexplm-in-data-theft-attacks/>
- [7] The Hacker News: Cl0p Affiliates Target Internet-Exposed PTC Windchill and FlexPLM. <https://thehackernews.com/2026/07/cl0p-affiliates-target-internet-exposed.html>